

Customer Support Q&A API

Node.js 20+ | Express 5 | OpenAI SDK | Helmet | Rate limiting | Stable JSON errors

DELIVERY	PROVIDER	SECURITY	QUALITY
Authenticated REST API	OpenAI Responses API	Strong bearer auth + limits	29 tests + 89% branches

Architecture

EDGE	APPLICATION	AI ADAPTER	OPERATIONS
Helmet, 32 KB JSON limit, auth-failure IP control, bearer authentication, paid-request limit.	Question schema, prompt boundaries, bundled policy context, response normalization.	Responses API, store: false, SDK timeout/retry, completed-response enforcement.	Live and ready health checks, safe logs, graceful shutdown, OpenAPI contract.

HTTP surface

METHOD	ROUTE	PURPOSE
GET	/health/live	Process liveness
GET	/health/ready	Required-secret readiness
POST	/support/ask	Authenticated support answer

Public error contract

400	invalid_request / invalid_json	401	unauthorized
413	payload_too_large	429	rate_limited
500	internal_error	502-504	provider / service errors

Security and resilience

- Validated independent inbound secret	- store: false provider requests
- Timing-safe authentication	- Completed output required
- Bounded request size and question length	- Redacted public errors
- Configurable proxy trust	- Per-process rate limiting

Verification

29 tests exercise application logic, the local HTTP surface, and the acceptance gate without paid provider calls. CI enforces at least 85% branch coverage and validates the complete OpenAPI contract plus 32 versioned evaluation cases on Node.js 20, 22, and 24.

Evidence scope

Fictional context; prompt-only grounding; no retrieval or citations; paid live quality evaluation pending; no client deployment or measured business outcome claimed.

Run locally

npm ci	npm run check	npm start
--------	---------------	-----------

Verified locally 2026-07-17 | release v2.1.1 | 29 tests | github.com/bazhinapolly/customer-support-qna-api
Production rollout requires managed secrets, TLS, observability, distributed limits, approved content, and quality evaluation.